

11_API_Architecture.md

Part 3 — Security, Error Handling & API Governance

API Security

Authentication

- Clerk Authentication
 - Bearer Token
 - JWT Validation
 - Secure Session Management
-

Authorization

Role-Based Access Control (RBAC)

Roles

- Guest
- User
- Admin

Authorization should be verified on every protected endpoint.

Input Validation

Every request must validate:

- Required fields
- Data types
- Value ranges
- String length
- Enum values
- File size (if applicable)

Invalid requests must return HTTP **422**.

Rate Limiting

Default Limits

Endpoint Type	Limit
Public APIs	100 requests/minute
Authenticated APIs	300 requests/minute
AI APIs	30 requests/minute
Admin APIs	100 requests/minute

When exceeded:

429 Too Many Requests

Error Handling

Standard Error Response

```
{
  "success": false,
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Invalid request data.",
    "details": []
  }
}
```

Error Codes

Code	Description
VALIDATION_ERROR	Invalid request
UNAUTHORIZED	Authentication required
FORBIDDEN	Permission denied
NOT_FOUND	Resource not found
CONFLICT	Duplicate resource
RATE_LIMIT_EXCEEDED	Too many requests

Code	Description
INTERNAL_SERVER_ERROR	Unexpected server error

Logging Strategy

Log

- API Requests
- API Errors
- Authentication Events
- Admin Actions
- AI Requests
- Trade Executions

Do Not Log

- Passwords
- Tokens
- Sensitive personal information

API Performance Standards

Target Response Time

Endpoint	Target
Authentication	<300 ms
Portfolio	<500 ms
Market Data	<500 ms
Trading	<700 ms
AI Coach	<5000 ms

Caching Strategy

Cache

- Market Overview
- Stock Prices
- Leaderboards
- Learning Courses

Do Not Cache

- User Portfolio
- Transactions
- Authentication
- AI Conversations

API Documentation Standard

Every endpoint must include:

- Endpoint
- Description
- Authentication
- Parameters
- Request Body
- Success Response
- Error Responses
- Status Codes
- Example Request
- Example Response

Documentation Format

- OpenAPI 3.1
- Swagger UI

API Versioning Policy

Major Version

Breaking Changes

Example

```
/api/v2
```

Minor Version

- New endpoints
- Backward compatible features

Patch Version

- Bug fixes
- Documentation updates

Deprecation Policy

Deprecated endpoints should:

- Remain available for one major version.
 - Include deprecation warnings.
 - Be documented with migration guidance.
-

API Testing Requirements

Every endpoint must have:

- Unit Tests
- Integration Tests
- Authentication Tests
- Authorization Tests
- Validation Tests
- Performance Tests

Target Test Coverage

≥ 90%

API Governance

Rules

- No breaking changes without version increment.
 - Every endpoint must be documented.
 - Every endpoint requires validation.
 - Every protected endpoint requires authentication.
 - Every API change requires code review.
 - Every release updates API documentation.
-

API Review Checklist

Before Release

- Endpoint documented
- Validation implemented
- Authentication verified

- Authorization verified
 - Rate limiting enabled
 - Error responses standardized
 - Logging enabled
 - Tests passing
 - Performance verified
-

Related Documents

- 10_Database_Architecture.md
 - 12_Engineering_Standards.md
 - MASTER_CONTEXT.md
-

Approval Status

Version: 1.0.0

Status: Draft

End of Document